CASE STUDY REPORT

Preventing Supply Chain Cyberattacks: A Case Study of the SolarWinds Orion Attack

Submitted by: -

Group No.: 16

Name	Prn
Ananya Patni	23070123023
Arya Shahi	23070123030
Ishaan Kukade	23070123062
Jatin Gurjar	23070123067

Department of Electronics and Telecommunication Engineering

Symbiosis Institute of Technology, Pune Campus

Symbiosis International (Deemed University)



Subject: Cyber Security

Batch: 2023–27

Semester: VII

Faculty: Dr. Mangal Singh

Date of Submission: 15 October 2026

INDEX

S. No.	Title	Page No.
1	Abstract	3
2	Introduction	4
3	Case Background	5
4	Literature Review	6
5	Methodology	8
8	Implementation Details and Proposed Security Controls	9
9	Results and Discussion	10
11	Conclusion	11
12	References	12

Abstract

At the end of 2020, when the world was dependent on technology a catastrophic event disturbed top tech companies and US agencies. There was a supply chain breach that involved the SolarWinds Orion system. The breach in SolarWinds' system not only hampered the single company but also thousands of organizations and agencies. But why did a single company's loss trigger disturbance within other organizations? It had a domino effect on them. The software company provides system management tools for network and infrastructure monitoring and other services required to most of the organizations around the globe. Orion is a system that primarily monitors the software performance of a product. The system had access to all the critical information and system performance data, which was therefore a golden loophole. Using this golden opportunity, the hack compromised the data, networks, and systems of thousands of application users, which acted as an update but actually was the backdoor malware. All this happened via the method known as a supply chain attack, which works by using the third party to manipulate the organization's system rather than directly attacking the network. In simple terms, consider this a Trojan's horse. Instead of attacking the main door, it secretly enters via the backdoor, dressed as a trusted individual, and has direct access to all the private information. This report is a qualitative single-case study. It explains how the attack worked, why it stayed hidden for about 14 months, how it was contained, and what the case teaches about preventing similar attacks. It also compares SolarWinds with software supply chain attacks reported in 2026 to show that the problem is still very much alive. The main finding is that the weak point was misplaced, automatic trust in a signed update, made worse by powerful monitoring tools and little visibility into how software is built. Layered defences such as zero trust, software bills of materials (SBOMs), secure build pipelines and honest incident disclosure can shrink the attacker's window.

Keywords: Supply chain attack, SolarWinds Orion, Trojanised update, SurnBurst, FireEeye.

1. Introduction

Several organizations, agencies and IT firms are interdependent and prevalently use third-party software for monitoring and operations. Trust between users and providers is built gradually, and that gives rise to an increased number of customers in the market over time. Such trust can lead long-term customers to usually ignore or overlook occasional updates due to the overall trustworthiness and integrity of the company. The supply chain attack was something nobody fathomed because of its sheer scale and the credibility associated with SolarWinds. As part of scrutiny, user companies often have protocols that look for digital signatures as a token of proof of credibility. At the end of 2020, the cybersecurity company FireEye (Mandiant) warned of the breach through a Trojanised update to the SolarWinds Orion system. Emergency directives commanded all users to disconnect or shut down their devices till further notice.

Problem statement:

Traditional security relies on the assumptions that the threats come from outside and the software from a trusted vendor is safe. A supply chain attack contradicts both of these assumptions. This report addresses the following questions: how was an ordinary update turned into a tool for cyberattack, why did the existing defences not detect it for such a long period of time and what can be done differently.

Why this topic is relevant to today's challenges:

The SolarWinds attack occurred some years ago, but it is not outdated. Supply chain attacks became very common in the current threat landscape. According to the last data, the XZ Utils compression library was found to have a backdoor in 2024, which CISA (2024) identified as CVE-2024-3094. The frequency of supply chain attacks continues to increase in 2026. Zscaler's ThreatLabz team reported five major software supply chain attacks in March 2026, one of them is the compromise of the Axios npm package (Zscaler ThreatLabz, 2026). Axios is a JavaScript library with over 100 million weekly downloads (Trend Micro, 2026). Microsoft described the ChainDrop worm that spreads itself and steals credentials, which was hidden in over 400 npm packages (Microsoft Threat Intelligence, 2026a).

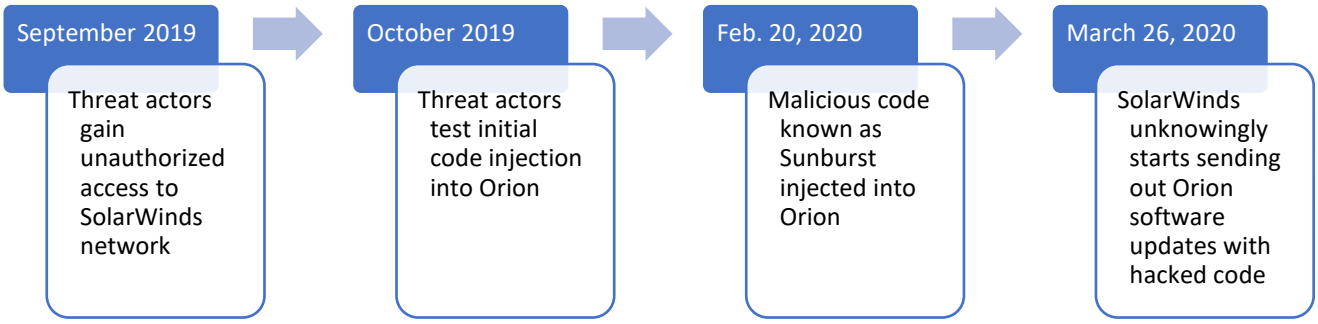
Objective

- To explain in detail how the SolarWinds Orion supply chain attack was carried out.
- To find the gaps and loopholes that allowed an unusually long dwell time.
- To propose a methodology to mitigate the unseen attack and constant self monitoring
- To compare SolarWinds with current (2026) supply chain incidents and draw practical lessons for prevention.

2. Case Background:

SolarWinds is a major software company providing system management tools for network and infrastructure monitoring and other technical services. This company is located in Tulsa, Okla and amongst their famously used products is an IT performance monitoring called Orion.Being a performance monitoring system it has the access to all the private resources. As the company handles the supply of so many companies, it was the easy target for the attackers.This attack is notable as more than 30000 public and private organizations used the Orion network management and this was a catastrophic failure as all the private details were also attached with it.

The timeline of the attack:



As per the study, more than 18000 users updated the malicious software and the severe problem here was that it was left undetected for around 14 months. The amount of private information that must have been compromised is unfathomable.

The breach was detected by a company called FireEye as their system issued warnings about something unconventional in their customer systems. The company then labelled this hack as UNC2452 and identified this as a trojanized attack. This hidden attack was labelled as SunBurst.

After the confirmation, all other organizations also responded to it, including Microsoft. FireEye later collaborated with GoDaddy in order to isolate the infected nodes and stop the further exploitation. They did this by using a kill switch that worked by preventing SurnBurst from operating further.

This cure is temporary and till date the SurnBurst is still alive. The purpose of the attack is still not understood but the fact can be comprehended that the private data was to be compromised.

3. Literature Review

After going through theories, research papers, articles associated with SolarWinds Orion case, we understood that interdependence, blindly trusting a third party and weak visibility across software development and distribution systems. Rather than throwing the limelight only on the incident, we analyze other aspects of supply chain security breaches and other terms which should be taken into consideration.

Research Context

The review primarily blames the open source and third party components as they are a free gateway for many attackers. Several softwares that are prevalently used in applications are dependent on the same, thus creating an entry route for the attackers. The review not only goes with the theoretical concepts but keeps account of mapped controls, risk assessments and attack taxonomies. Aspects like cloud involved softwares still fall in the gaps of the research.

Theme	**Synthesis**	**Representative support**
Case significance	Being the software provider of several MNCs and government applications, the compromise of the software is highly talked about. The supply chain attack significantly holds the learnings from lenient security charges and blunders.	• Tan, Z.-R., Parambath, S., Anagnostopoulos, C., Singer, J., & Marnerides, A. (2025). Advanced Persistent Threats Based on Supply Chain Vulnerabilities: Challenges, Solutions, and Future Directions. *IEEE Internet of Things Journal, 12*, 6371-6395. https://doi.org/10.1109/jiot.2025.3528744 • Martinez, J., & Durán, J. M. (2021). Software Supply Chain Attacks, a Threat to Global Cybersecurity: SolarWinds' Case Study. *International Journal of Safety and Security Engineering*. https://doi.org/10.18280/ijsse.110505 • Olutimehin, D. O. (2024). Cybersecurity in supply chains: Addressing emerging threats with strategic measures. *International Journal of Management &*

		Entrepreneurship Research. https://doi.org/10.51594/ijmer.v6i6.1241
Attack mechanism	A hidden malicious code that acted similar to a trojan horse was distributed through a credible vendor via updates.	• Hammi, B., Zeadally, S., & Nebhen, J. (2023). Security Threats, Countermeasures, and Challenges of Digital Supply Chains. *ACM Computing Surveys, 55*, 1 - 40. https://doi.org/10.1145/3588999 • Martinez, J., & Durán, J. M. (2021). Software Supply Chain Attacks, a Threat to Global Cybersecurity: SolarWinds' Case Study. *International Journal of Safety and Security Engineering*. https://doi.org/10.18280/ijsse.110505
Conceptual framing	Analyzers view this as an advanced persistent threat that exploits the resource in the long term and can have access to private networks.	• Ghanbari, H., Koskinen, K., & Wei, Y.-B. (2024). From SolarWinds to Kaseya: The rise of supply chain attacks in a digital world. *Journal of Information Technology Teaching Cases, 16*, 198 - 205. https://doi.org/10.1177/20438869241299823
Main lesson	Even if the vendor is credible, it is essential to run regular check ups and monitoring for the security and health of the software.	
Mitigation direction	Regular monitoring, audits, DevSecOps.	

4. Methodology

We are considering the MAFIA game and all the resources as the villagers. Our drawback in the case study is that the attack is hidden and is left undiscovered, hence we are modelling our software ecosystem as a village, with villagers not knowing who the mafia is. With endless hidden security keys and constant monitoring (that again will be hidden), it is easy to separate out that part of the resource which is compromised.

In our scenario, the moderator shall do his work silently and monitor every movement with eyes open but as a silent spectator. The hidden state of moderator will be a trap for the mafia and thus protecting the entire village.

Every villager is linked or dependent to other villagers, same way the software packages have similar dependencies. We are also using a priority queue to investigate the abnormality based suspicious packet first. By following this, the defender can focus on the most urgent threats. The resource is huge in our case and hence we can find a genuine compromise. There are possibilities of countering false positives and hence we measure detection time, affected packages and recovery time. We then compare these results with the original workflow and then determine whether prioritization and early containment actually improve security.

Our above study is one method and the other method we are using is an analysis of a single case in SolarWinds Orion attack. The timeline is rebuilt from public reports (Mandiant, CISA, Microsoft), and the attacker's actions resemble the MITRE ATT&CK framework.

Villager	A software package
Mafia	Compromised package
Links between the villagers	Interdependency
Moderator	Hidden monitoring layer that is a silent spectator
Night attack	Spread of attack by using interdependency
Alienating or casting out a villager	Isolating the suspicious package.

Model design:

- A graph (data structure analysis, G=(V,E)) is taken into consideration and will help us show the dependency.
- We will randomly choose a node and consider it as compromised.
- A moderator will be allotted, who will keep an eye on all the movements, updates and in the scenario will give a score to each node between 0 and 1. The basis of the score will be determined by the behaviour and obnoxious network connections.
- Using the score all the nodes will be arranged in max heap order, this helps us find the highest score node at priority and securing the other part that is not affected.
- This process will help us segregate the compromised node and save the other nodes from getting attacked.

Baseline and Comparison

The infected graph is run under two circumstances, first being baseline and other will be the proposed workflow(priority queue and hidden monitoring). The baseline will have no priority and follow the FIFO concept, this aligns with our concept of routine updates that were held by SolarWinds.

In this workflow what we are procuring is detection time, affected packages, recovery time and the false positive rates. These parameters determine the efficiency of our proposed methodology.

7. Implementation Details and Proposed Security Controls

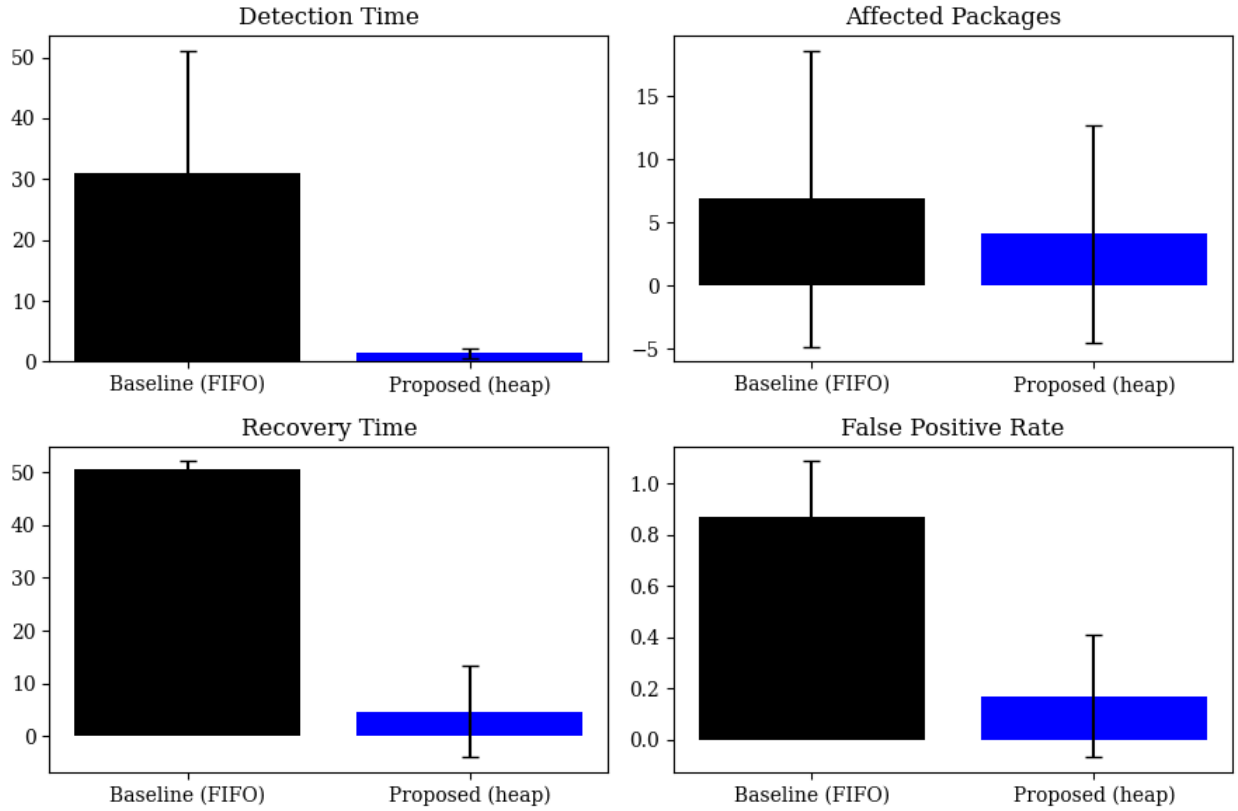
Algorithm:

1. Build dependency graph G with N nodes
2. Infect one random seed node
3. Repeat each time step:
    a. Infected nodes infect dependents with probability p
    b. Moderator updates anomaly scores (infected: high, healthy: low, plus noise)
    c. Baseline: pick next node by FIFO | Proposed: pop highest score from heap
    d. If node is infected: isolate it and queue its dependents

Else: record a false positive

4. Stop when no infected nodes remain; record the four metrics

8. Results and Discussion



N=50, runs=1000, p=0.3, noise=0.15

Metric	Baseline (mean ± sd)	Proposed (mean ± sd)
Detection Time	31.03 ± 19.93	4.08 ± 8.63
Affected Packages	6.87 ± 11.72	4.08 ± 8.63
Recovery Time	50.61 ± 1.44	4.70 ± 8.68
False Positive Rate	86.95% ± 21.65%	16.93% ± 23.95%

- Added the FIFO baseline, run on the same graph and seed node as the proposed workflow.

- Scores = 0 to 1 (infected about 0.7, healthy about 0.3, noise 0.15), so false positives can also take place
- Fixed the false positive formula, added fixed random seeds, and averaged over 1,000 runs.
- The graph is now scale free, built with NetworkX.
- Added a black-and-blue chart that meets the report's colour rule

10. Conclusion

The SolarWinds attack was an eye-opener for several companies and government firms for using credible software updates. We never know the uncertainties and flaws that lie in a trusted resource. It is essential to go through all the terms and conditions without haphazardly accepting them. The above methodology is a small solution and a step that should be deployed by all the open source software users for monitoring purposes. Even though the third party software is providing their services, it is essential for the company to have its own monitoring system that keeps track of what exactly is taking place inside.

Companies that recognized such as FireEye also went with the similar strategies and there are cyber security companies that are still working on this massive hack that is still operational till date. As per our understanding and knowledge we brainstormed and came to this solution of using 'Mafia Game' and try to minimize the effect that shall eventually mitigate the spread of infection.

References

[1] B. Gokkaya, L. Aniello, and B. Halak, "Software supply chain: A taxonomy of attacks, mitigations and risk assessment strategies," *J. Inf. Secur. Appl.*, vol. 97, Art. no. 104324, 2026, doi: 10.1016/j.jisa.2025.104324.

[2] Z.-R. Tan, S. Parambath, C. Anagnostopoulos, J. Singer, and A. Marnerides, "Advanced persistent threats based on supply chain vulnerabilities: Challenges, solutions, and future directions," *IEEE Internet Things J.*, vol. 12, pp. 6371–6395, 2025, doi: 10.1109/JIOT.2025.3528744.

[3] J. Martinez and J. M. Durán, "Software supply chain attacks, a threat to global cybersecurity: SolarWinds' case study," *Int. J. Saf. Secur. Eng.*, 2021, doi: 10.18280/ijsse.110505.

[4] H. Ghanbari, K. Koskinen, and Y.-B. Wei, "From SolarWinds to Kaseya: The rise of supply chain attacks in a digital world," *J. Inf. Technol. Teach. Cases*, vol. 16, pp. 198–205, 2024, doi: 10.1177/20438869241299823.

[5] A. Kruti, U. Butt, and R. B. Sulaiman, "A review of SolarWinds attack on Orion platform using persistent threat agents and techniques for gaining unauthorized access," *arXiv:2308.10294*, 2023, doi: 10.48550/arXiv.2308.10294.

[6] B. Hammi, S. Zeadally, and J. Nebhen, "Security threats, countermeasures, and challenges of digital supply chains," *ACM Comput. Surv.*, vol. 55, pp. 1–40, 2023, doi: 10.1145/3588999.

[7] E. O'Donoghue, Y. D. Hastings, E. Ortiz, and A. R. M. Muneza, "Software bill of materials in software supply chain security: A systematic literature review," *arXiv:2506.03507*, 2025, doi: 10.48550/arXiv.2506.03507.

[8] D. O. Olutimehin, "Cybersecurity in supply chains: Addressing emerging threats with strategic measures," *Int. J. Manag. Entrepreneurship Res.*, vol. 6, no. 6, 2024, doi: 10.51594/ijmer.v6i6.1241.

[9] S. Peisert, B. Schneier, H. Okhravi, F. Massacci, T. Benzel, C. Landwehr, M. Mannan, J. Mirkovic, A. Prakash, and J. Michael, "Perspectives on the SolarWinds incident," *IEEE Secur. Privacy*, vol. 19, no. 2, pp. 7–13, Mar./Apr. 2021, doi: 10.1109/MSEC.2021.3051235.

[10] P. Ladisa, H. Plate, M. Martinez, and O. Barais, "SoK: Taxonomy of attacks on open-source software supply chains," in *Proc. IEEE Symp. Secur. Privacy (SP)*, 2023, pp. 1509–1526, doi: 10.1109/SP46215.2023.10179304.

[11] M. Ohm, H. Plate, A. Sykosch, and M. Meier, "Backstabber's Knife Collection: A review of open source software supply chain attacks," in *Proc. DIMVA*, 2020, pp. 23–43, doi: 10.1007/978-3-030-52683-2_2.

[12] A.-L. Barabási and R. Albert, "Emergence of scaling in random networks," *Science*, vol. 286, no. 5439, pp. 509–512, Oct. 1999, doi: 10.1126/science.286.5439.509.

[13] R. Pastor-Satorras and A. Vespignani, "Epidemic spreading in scale-free networks," *Phys. Rev. Lett.*, vol. 86, no. 14, pp. 3200–3203, Apr. 2001, doi: 10.1103/PhysRevLett.86.3200.

[14] V. Chandola, A. Banerjee, and V. Kumar, "Anomaly detection: A survey," *ACM Comput. Surv.*, vol. 41, no. 3, Art. no. 15, 2009, doi: 10.1145/1541880.1541882.

[15] A. A. Hagberg, D. A. Schult, and P. J. Swart, "Exploring network structure, dynamics, and function using NetworkX," in *Proc. 7th Python Sci. Conf. (SciPy)*, 2008, pp. 11–15.

[16] T. H. Cormen, C. E. Leiserson, R. L. Rivest, and C. Stein, *Introduction to Algorithms*, 4th ed. Cambridge, MA, USA: MIT Press, 2022.

[17] Cybersecurity and Infrastructure Security Agency (CISA), "Emergency Directive 21-01: Mitigate SolarWinds Orion code compromise," Dec. 13, 2020. [Online]. Available: https://www.cisa.gov/emergency-directive-21-01. [Accessed: Oct. 16, 2026].

[18] CISA, "Alert (AA20-352A): Advanced persistent threat compromise of government agencies, critical infrastructure, and private sector organizations," Dec. 17, 2020. [Online]. Available: https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a. [Accessed: Oct. 16, 2026].

[19] FireEye, "Highly evasive attacker leverages SolarWinds supply chain to compromise multiple global victims with SUNBURST backdoor," Dec. 13, 2020. [Online]. Available: https://www.mandiant.com/resources/blog/evasive-attacker-leverages-solarwinds-supply-chain-compromises-with-sunburst-backdoor. [Accessed: Oct. 16, 2026].

[20] Microsoft Security Response Center, "Analyzing Solorigate, the compromised DLL file that started a sophisticated cyberattack, and how Microsoft Defender helps protect customers," Dec. 18, 2020. [Online]. Available: https://www.microsoft.com/en-us/security/blog/2020/12/18/analyzing-solorigate-the-compromised-dll-file-that-started-a-sophisticated-cyberattack-and-how-microsoft-defender-helps-protect/. [Accessed: Oct. 16, 2026].

[21] CrowdStrike, "SUNSPOT: An implant in the build process," Jan. 11, 2021. [Online]. Available: https://www.crowdstrike.com/en-us/blog/sunspot-malware-technical-analysis/. [Accessed: Oct. 16, 2026].

[22] MITRE, "Supply chain compromise: Compromise software supply chain, Technique T1195.002," MITRE ATT&CK. [Online]. Available: https://attack.mitre.org/techniques/T1195/002/. [Accessed: Oct. 16, 2026].

[23] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero trust architecture," NIST, Gaithersburg, MD, USA, Spec. Publ. 800-207, Aug. 2020, doi: 10.6028/NIST.SP.800-207.

[24] M. Souppaya, K. Scarfone, and D. Dodson, "Secure software development framework (SSDF) version 1.1," NIST, Gaithersburg, MD, USA, Spec. Publ. 800-218, Feb. 2022, doi: 10.6028/NIST.SP.800-218.

[25] National Telecommunications and Information Administration (NTIA), "The minimum elements for a software bill of materials (SBOM)," Jul. 12, 2021. [Online]. Available: https://www.ntia.gov/report/2021/minimum-elements-software-bill-materials-sbom. [Accessed: Oct. 16, 2026].

[26] "Hacked IT firm says fewer than 18K customers compromised," *Business Insurance*. [Online]. Available: https://www.businessinsurance.com/hacked-it-firm-solarwinds-says-fewer-than-18000-customers-compromised/. [Accessed: Oct. 16, 2026].

[27] Zscaler ThreatLabz, "Supply chain attacks surge in March 2026." [Online]. Available: https://www.zscaler.com/blogs/security-research/supply-chain-attacks-surge-march-2026. [Accessed: Oct. 16, 2026].

[28] Malwarebytes, "Axios supply chain attack chops away at npm trust," Mar. 31, 2026. [Online]. Available: https://www.malwarebytes.com/blog/news/2026/03/axios-supply-chain-attack-chops-away-at-npm-trust. [Accessed: Oct. 16, 2026].

[29] Microsoft Threat Intelligence, "ChainDrop supply chain compromise: Anatomy of a self-propagating worm," Aug. 4, 2026. [Online]. Available: https://www.microsoft.com/en-us/security/blog/2026/08/04/chaindrop-supply-chain-compromise-anatomy-self-propagating-worm/. [Accessed: Oct. 16, 2026].

[30] CISA, "Reported supply chain compromise affecting XZ Utils data compression library, CVE-2024-3094," Mar. 29, 2024. [Online]. Available: https://www.cisa.gov/news-events/alerts/2024/03/29/reported-supply-chain-compromise-affecting-xz-utils-data-compression-library-cve-2024-3094. [Accessed: Oct. 16, 2026].